

Capstone Project: Full VAPT Engagement

A full-scope penetration test was conducted against a HackTheBox virtual machine to simulate a real-world security assessment. The engagement followed the **PTES (Penetration Testing Execution Standard)** methodology and included reconnaissance, exploitation, post-exploitation, remediation, and validation.

Test Environment

- **Attacker OS:** Kali Linux
- **Target:** HackTheBox VM (Lame)
- **Target IP:** 192.168.1.200
- **Tools Used:** Metasploit, Burp Suite, OpenVAS, Google Docs

Timestamp	Target IP	Vulnerability	PTES Phase
2025-08-30 15:00:00	192.168.1.200	VSFTPD RCE	Exploitation

PTES Report

Executive Summary

This penetration testing engagement assessed the security posture of a HackTheBox virtual machine using a structured PTES approach. The objective was to identify exploitable vulnerabilities, demonstrate real-world impact, and provide actionable remediation guidance. A critical remote code execution vulnerability was successfully exploited, resulting in full system compromise.

Attack Timeline

Reconnaissance:

Network scanning identified open FTP and HTTP services. Version enumeration revealed an outdated VSFTPD service vulnerable to a known backdoor exploit.

Exploitation:

Metasploit module `exploit/unix/ftp/vsftpd_234_backdoor` was used to gain remote code execution, resulting in shell access to the target system.

Post-Exploitation:

The attacker confirmed system access and privilege context. Sensitive system files were accessible, demonstrating full compromise.

API Testing:

Burp Suite was used to analyze API traffic. Weak input validation and lack of authentication controls were identified, increasing attack surface risk.

Validation:

OpenVAS scans were performed before and after remediation to validate risk reduction.

Remediation Plan

- Patch or upgrade VSFTPD to a secure version
- Disable unused services
- Implement strong input validation on APIs
- Enforce least-privilege access controls
- Conduct regular vulnerability scanning and patch management

Rescan Results (OpenVAS)

Post-remediation OpenVAS scans confirmed the removal of the critical FTP vulnerability and reduced overall risk exposure.

Non-Technical Executive Briefing

This security assessment simulated a real-world cyberattack against an internal system to evaluate its defenses. A critical vulnerability was identified that allowed attackers to remotely access the system without authentication. Exploiting this weakness resulted in full system compromise, exposing sensitive data and administrative functions.

The root cause was outdated software and insufficient security controls. Additional weaknesses were found in API input handling, increasing the likelihood of future attacks if left unresolved.

Remediation steps were applied, including system patching, access restriction, and configuration hardening. A follow-up security scan confirmed that the most severe risks were successfully mitigated.

This engagement highlights the importance of regular security testing, timely patching, and enforcing least-privilege access. Implementing these controls significantly reduces the risk of unauthorized access and potential business impact.

Submission Checklist

- ☐ Exploitation demonstrated
- ☐ PTES methodology followed
- ☐ Evidence documented
- ☐ Remediation validated
- ☐ Executive briefing completed